Course Code: ITA1439 **Course Name: Ethical Hacking**

Slot: A

CO1 - ASSIGNMENT 1

Nature of Assignment: Individual **Duration:** 1 Week **Total Marks:** 50

Student Name: Ajmal Rahman A
Reg. No: 192324094
Date: 01-11-2026

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment Title: Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

Scenario - University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are

set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

Task 1 - Formulate the Enquiry and Framework Blueprint (4 marks)

We call the framework the University Engagement Governance Framework (UEGF). Version numbers are used throughout: 0.9 is the first draft built in Tasks 1 to 8, 1.0 is the draft after the walkthrough in Task 9, 1.1 is the version after the scalability evaluation in Task 10, and 2.0 is the version rebuilt for the changed requirement in Task 11. Everything stays on paper or inside an isolated lab. No live exploitation is carried out anywhere in this document.

1.1 Requirements drawn from the scenario

The scenario boils down to nine things the university needs to be able to say "yes" to before it lets anyone test its systems. Table 1 turns each of them into a governance requirement and names the part of the framework that answers it. The control identifiers in the last column (AUTH, ROE, LEG, DATA, EC, LAB, DISC, LOG) are defined in the later tasks, and the full catalogue is gathered in Table 15.

Table 1. Engagement-governance requirements derived from the scenario

ID	Requirement	Framework element	Controls
R1	Every test must rest on written permission from someone entitled to give it, and that permission must be checkable.	Authorization layer	AUTH-1, AUTH-2
R2	Systems must be named precisely, 20 now and many more later, so that an out-of-scope request can be spotted.	Scope register and RoE	ROE-1
R3	Portal, LMS, mail and network are live during teaching, so testing must not damage them or collide with exams.	Testing windows, blackout calendar, stop triggers	ROE-2, ROE-3, ROE-4
R4	Systems that hold personal data need extra clearance and a rule against copying data out.	Legal gate and data handling	LEG-6, DATA-1 to DATA-3
	The kinds of attacker the university worries about must be described, so tests are chosen for a reason.	Threat model and test profiles	TP-1 to TP-4
R8	Indian law and, where relevant, foreign law must be respected; every test needs an audit trail, and testers (internal or external) must follow a checkable code of conduct.	Legal mapping, code of conduct, register and log	LEG-1 to LEG-6, EC-1 to EC-6, LOG-1
R9	Findings must reach the owner fast and be disclosed in an orderly way, never by accident.	Authorization and disclosure layer	DISC-1 to DISC-4
R10	Hands-on techniques must be practised somewhere that cannot hurt a real system.	Isolated lab	LAB-1 to LAB-4
R12	The same framework must still work for the whole university and for outside assessors.	Tiered approval, reusable documents, versioning	Tasks 10 and 11

1.2 Systems in scope

The scenario names four service families: the student portal, the learning-management system, the email service and the campus network. We expanded them into twenty registered systems (Table 2) by adding the components they depend on, such as the databases, the single sign-on directory and the firewall. Each system is given a tier. T1 means the system holds or directly exposes personal data, T2 is infrastructure that supports T1 systems, and T3 is public or low-sensitivity. The last column gives the default test mode: **full** (scanning and authenticated testing inside the window) or **config** (configuration and patch review plus non-intrusive scanning only). Every T1 database is config-only because nobody needs to touch real student records to learn whether the database is hardened.

Table 2. Scope register: the twenty systems in the first wave (host names follow the pattern <name>.univ.example.edu, addresses are illustrative values on 10.20.0.0/16)

ID	System	Tier / mode	ID	System	Tier / mode
SYS-01	Student Portal web application	T1 / Full	SYS-11	VPN gateway	T2 / Full

ID	System	Tier / mode	ID	System	Tier / mode
SYS-02	Student Portal database	T1 / Config	SYS-12	Single sign-on directory	T1 / Config
SYS-03	LMS application	T1 / Full	SYS-13	Staff administration portal	T1 / Full
SYS-04	LMS database	T1 / Config	SYS-14	Library system	T3 / Full
SYS-05	Mail gateway	T2 / Config	SYS-15	Fee-payment interface (university side)	T1 / Config
SYS-06	Mailbox store	T1 / Config	SYS-16	Examination results server	T1 / Config
SYS-07	Core switch stack	T2 / Config	SYS-17	Backup server	T2 / Config
SYS-08	Perimeter firewall	T2 / Config	SYS-18	Public website	T3 / Full
SYS-09	Wi-Fi controller	T2 / Full	SYS-19	Departmental file server	T2 / Full
SYS-10	DNS and DHCP server	T2 / Full	SYS-20	Teaching-lab VLAN gateway	T3 / Full

Nine systems are T1, eight are T2 and three are T3. The register is the single list that the rest of the framework consults, which is why new systems are added to it before they can be named in any request.

1.3 Stakeholders

Table 3. Stakeholders and their roles

Stakeholder	Interest and role in the framework
Registrar's office (executive sponsor)	Owns the university's risk and reputation; final escalation point (Level 4).
Engagement Authority (EA), the CISO or IT Director	Approves engagements, signs authorization forms, can suspend any test.
System owner (SO)	The person accountable for a registered system; confirms scope, receives findings, fixes them.
Requesting department, Test Lead and testers	The department asks for a test but cannot approve it; testers (internal or external) work inside the signed scope under the code of conduct.
DPO, legal counsel, Disclosure Coordinator, network operations	Clear tests touching personal data and decide legal conflicts; run the reporting clock; watch live systems and can trigger a stop. The Engagement Authority may name a deputy for absences.
Students and staff (data principals)	Not involved in decisions, but their data is the thing most at risk; the framework exists partly for them.

1.4 Expected activities and constraints

The expected activities are discovery and mapping, vulnerability scanning, configuration and patch review, authenticated web-application checks with test accounts, password-policy audit, Wi-Fi and VPN assessment, lab rehearsal, and reporting with retest. The riskiest to live service are the authenticated web checks and the Wi-Fi and VPN work, so those are limited to a night-time window; the rest are low risk. Lab rehearsal never touches a live system.

The constraints that shape the design are: live services that must stay up during teaching and exams; personal data behind nine of the twenty systems; the IT Act, 2000 now and the DPDP Act, 2023 being phased in, with some systems possibly held by foreign providers; growth from about 20 systems and 50 staff to the whole university and outside assessors; a small governance team and one senior approver; and, for this work, design, documents and an isolated lab only.

1.5 Framework blueprint

Figure 1 shows how the parts cooperate. A request enters the authorization layer and receives an engagement number. That number is the key used by the scope and rules-of-engagement component, which also takes a test profile from the threat model. Scope decides whether personal data is in play, and if so the legal component must clear it. Only when authorization, scope, legal clearance, the code of conduct and a lab rehearsal are all in place does testing begin. Findings flow into the disclosure layer, but only after the finding report has been checked back against the scope register. Everything that happens is written to the register and log.

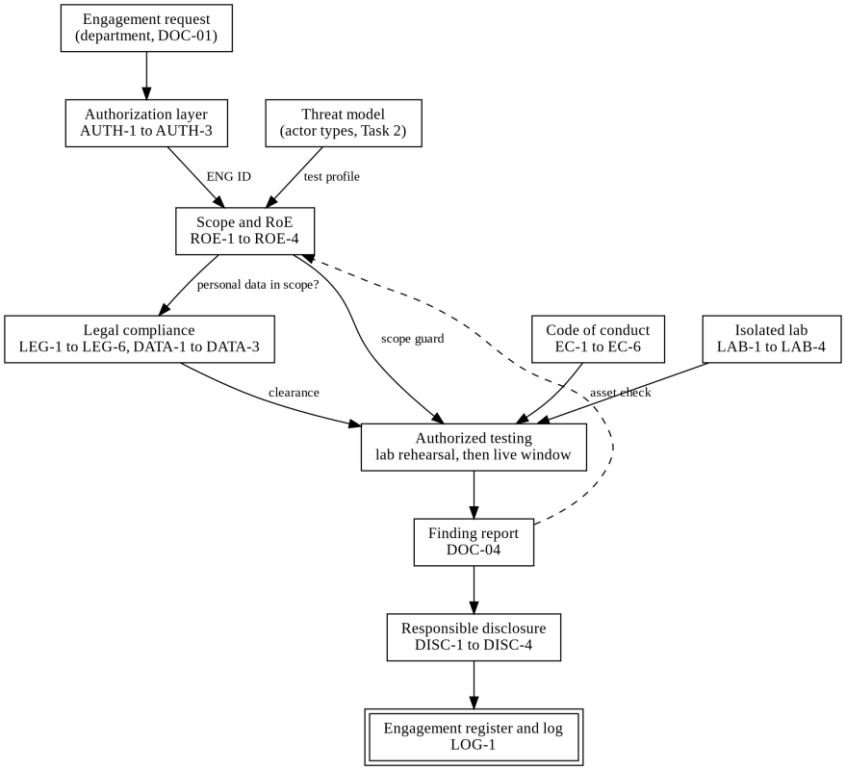


Figure 1. Blueprint of the University Engagement Governance Framework

The scenario insists that the framework must separate what is authorized, what is legal and what is appropriate. We handle that with three gates that every engagement must pass in order (Table 4). They are separate because each can fail while the others pass. A signed form does not make an illegal act legal, and a legal act can still be inappropriate for a university that has promised students their data is safe.

Table 4. The three gates: authorized, legal, appropriate

Gate	Question	Decided by	Evidence	Why permission alone is not enough
Authorized	Has someone entitled to permit this test given written, current permission for exactly this scope?	Engagement Authority and system owner	Signed DOC-02 with matching scope hash	A signed form for a host that is actually run by a bank partner: the university cannot give that permission.
Legal	Does the law allow this act on this system with this data, even with permission?	DPO and legal counsel	Legal gate record, DPO clearance	Permission to "copy the student table to prove the flaw": permission is there, but the data-protection duties still apply.
Appropriate	Is it proportionate and consistent with the university's duties and values?	Engagement Authority, code of conduct	Conduct decision rules EC-1 to EC-6	A legal, authorized load test run in the middle of a teaching day.

1.6 Enquiry questions

The framework must answer eight questions: **Q1** who may authorize a test and how that is proved later (Tasks 5, 6); **Q2** what exactly is in scope and how an out-of-scope request is caught before any packet is sent (Task 5); **Q3** which laws apply, and what changes when personal data is touched (Task 4); **Q4** which attackers the university defends against and how they shape the tests (Task 2); **Q5** how findings are disclosed, to whom and by when (Task 6); **Q6** where hands-on techniques can be practised safely (Task 7); **Q7** what keeps testers ethical and how drift is detected (Task 3); **Q8** whether the framework still works as the programme grows or the rules change (Tasks 10, 11).

1.7 Design criteria used as acceptance criteria

Table 5. Design criteria and acceptance tests

ID	Criterion	What it means	Acceptance test
C1	Traceability	Every test session maps to a signed, unexpired authorization in the register.	No session allowed without a matching register entry (tests TC-01 to TC-03).
C2	Containment	No action reaches a system that is not listed in the engagement.	Zero out-of-scope targets pass the scope guard (TC-04, TC-05).
C3	Legal alignment	Every legal requirement identified is tied to a named control.	No row of the legal table has an empty control column (Table 14).
C4	Safety of live services	Testing avoids teaching hours, exam and results weeks, and stops on service trouble.	No pass for tests outside window or in blackout (TC-06, TC-09).

ID	Criterion	What it means	Acceptance test
C5	Timeliness	Approvals and owner notification happen fast enough to be useful.	At least 95 percent of approvals within 5 working days and of owners notified within 1 working day, at both scales.
C6	Scalability	Growing from one department to the whole university must not make the process several times slower.	Large-programme approval turnaround no more than 1.5 times the small-programme figure.
C7	Reusability and checkability	Documents carry sensible defaults and are validated by test entries.	Valid, boundary and invalid cases all behave as expected (Table 36 and Table 37).

Rationale. The scenario warns that an unstructured approach causes unauthorized access, legal exposure, damage, unclear scope and uncoordinated disclosure. Each has a matching component: authorization, the legal gate, windows and stop triggers, the register, and the disclosure layer. The seven criteria are measurable, so Task 11 can check the final design against them.

Task 2 - Design a Hacker Threat Model and Classification (4 marks)

Classify the hacker types relevant to the university, map them to motivation, capability and targets, set consistent criteria and settle a borderline case.

2.1 Classification scheme and naming

Hacker labels are used loosely in the media, so we classify by four observable attributes instead of by reputation. An actor is described by authorization (is there written permission covering the act), intent (why they act), relationship (do they hold a legitimate university account) and resources (capability level and any sponsor). Capability is graded on a four-step scale: **L1** uses ready-made tools without adapting them, **L2** adapts public exploits and writes simple scripts, **L3** builds custom tools and chains weaknesses, **L4** has sustained funding, custom exploits and the patience for long campaigns.

Names follow the pattern H-<TYPE> with optional flags: **+I** for an actor who holds an internal account, **+D** when someone else's data was actually reached, and **+P** when the account is privileged. So H-GH +I +D reads as a grey hat with an internal account who reached other people's data.

Table 6. Classification procedure (first matching step wins; ambiguous cases go to the scoring check in 2.3)

Step	Question, asked in this order	If yes, classify as
1	Written authorization covers the act and the act stays inside scope?	H-WH white hat
2	No authorization, and the actor abuses a legitimate account or trust they were given?	H-IN insider
3	Evidence of state direction or funding (at least two of: dedicated infrastructure, custom tooling, long persistence, targets tied to national interest)?	H-SS state-sponsored
4	A stated public cause, claimed openly?	H-HA hacktivist
5	Capability L1, ready-made tools, motive is notoriety or fun?	H-SK script kiddie
6	Motive is personal gain or deliberate harm?	H-BH black hat
7	None of the above: no authorization, no malicious gain, owner is told?	H-GH grey hat

2.2 Threat model: types mapped to motivation, capability and targets

Table 7. Hacker threat model for the university (likelihood and impact are qualitative judgements, not measured values)

Code	Type	Motivation	Capability	Likely targets at the university	Likelihood / impact (our estimate)
H-WH	White hat	Protect systems, professional duty, pay	L2 to L3	Only systems named in a signed engagement	Not a threat; the model for our own testers
H-GH	Grey hat	Curiosity, reputation, wish to help without asking	L2	Public-facing portal, LMS, public website	Medium / Medium
H-BH	Black hat	Money, data resale, ransom, fraud	L2 to L3	Fee-payment interface, results server, student records, mailbox credentials	Medium / High
H-SK	Script kiddie	Notoriety, boredom, dares	L1	Public website defacement, login pages, guest Wi-Fi	High / Low
H-HA	Hacktivist	Political or social cause	L1 to L2	Public website and portal, often around admissions or controversial events; denial of service	Medium / Medium
H-IN	Insider (malicious or negligent)	Grievance, gain, curiosity, carelessness	L1 to L3, with real access	Results server, grades, staff portal, staff mail, file servers	Medium / High
H-SS	State-sponsored	Espionage, long-term access	L4	Research data, staff mail, VPN gateway, single sign-on directory	Low / High

Likelihood and impact are our own judgements, used only to decide which test profiles run first, not as a risk score.

The threat model feeds the rest of the framework through four test profiles. Each profile is a package of techniques that the rules of engagement can allow or forbid as a unit.

Table 8. Test profiles derived from the threat model

Profile	Name	Actors modelled	What is allowed to be tested
TP-1	External, unauthenticated	H-SK, H-HA, H-BH	Discovery, scanning and configuration review of public-facing systems
TP-2	Authenticated ordinary user	H-GH +I, H-IN (student or staff)	Access-control and session checks using test accounts at student and staff level
TP-3	Privileged internal review	H-IN +P	Configuration, patch and policy review of admin interfaces and directories; read-only
TP-4	Persistent adversary	H-SS	Tabletop and design review only; no live simulation in the first wave

2.3 A borderline actor classified two ways

The case. A second-year student with an ordinary LMS login notices that changing the course number in a download link returns files from a course he is not enrolled in. He downloads three files to be sure, one of which is a marks sheet for about forty students. He says nothing for two days. Then he emails the IT helpdesk, explains the flaw, attaches one of the files as proof, and asks for nothing.

The case does not sit comfortably in any one box, so we tested three classifications against six observed facts. Each type has an expected value for each fact. Where a type does not care about a fact (it can go either way) that fact is left out of its score.

Table 9. Scoring three alternative classifications of the borderline actor

No.	Observed fact	Grey hat expects	Insider expects	Black hat expects	Observed in case
C1	No written authorization	Yes	Yes	Yes	Yes
C2	Intent not malicious	Yes	No	No	Yes
C3	Holds a legitimate internal account	Not decisive	Yes	No (usually external)	Yes
C4	Capability L1 or L2	Yes	Not decisive	Not decisive	Yes
C5	Other people's data was reached	Not decisive	Yes	Yes	Yes
C6	Voluntary disclosure to the owner	Yes	No	No	Yes
	Matches on the criteria that count	**4 of 4**	**3 of 5**	**2 of 5**	

- **Alternative A, insider (H-IN).** For: he holds a valid account and went beyond what the account was meant to see. Against: nothing in the case shows grievance, gain or abuse of trust. The flaw is a software defect that any student could reach, and calling every student with a login an insider would also teach students that reporting is dangerous.
- **Alternative B, black hat (H-BH).** For: access without permission and copying of personal data are exactly the acts the IT Act describes in section 43. Against: no sign of gain or onward use, the report was voluntary and came with evidence, and the "dishonestly or fraudulently" element of section 66 is hard to show.
- **Alternative C, grey hat (H-GH).** For: no authorization, benign intent, modest skill, reported to the owner. Against: he kept the files for two days and attached a real marks sheet, which is not harmless.

Final classification: H-GH +I +D. The grey-hat profile matches every criterion it cares about. The two flags carry what the label alone would hide: the actor is internal, and personal data was actually reached. The flags matter in practice because the +D flag moves the case into the incident procedure (LEG-5) and the DPO's review regardless of the actor's good intent. The classification therefore changes how the university treats the person (as a reporter, not as an attacker) without changing how it treats the data (as exposed). We chose it over the other two because classification should follow evidence of intent and behaviour, while consequences for the data follow from what was reached.

Task 3 - Create an Ethics and Code-of-Conduct Module (4 marks)

Define the ethical principles, build rules that detect unethical actions, test them on acceptable, borderline and unacceptable cases, and explain how the module preserves trust.

3.1 Principles

Eight principles govern an authorized engagement. They are short on purpose, since a tester under time pressure will remember eight lines and will not remember eight pages. Each principle is attached to at least one rule that can be checked (Table 10).

Table 10. Ethical principles of the code of conduct

ID	Principle	What it means in practice	Enforced by
P1	Written authorization	Nothing is touched until a signed, current authorization names the tester and the target.	EC-1
P2	Agreed scope	Only the listed assets, only inside the agreed window and dates.	EC-2, EC-3

ID	Principle	What it means in practice	Enforced by
P3	Confidentiality	What the test reveals belongs to the system owner and goes nowhere else.	Undertaking in DOC-03
P4	Integrity and no harm	Systems and data are left as they were found; services are not degraded.	EC-5
P5	Minimum data	See as little personal data as is needed to prove a flaw; never copy it off the system.	EC-4
P6	Honest reporting	Report what was found at the severity it deserves, including awkward findings and the tester's own mistakes.	EC-6
P7	Lawfulness	Do nothing that the law prohibits even if someone is willing to permit it.	Legal gate, LEG-1 to LEG-6
P8	Stop and ask	When unsure, pause and ask. Uncertainty is never a licence to continue.	Borderline rule below

3.2 Decision rules and detection checks

Before any action that could go wrong, the tester answers six questions with yes, no or unsure. The questions map one to one onto the rules EC-1 to EC-6.

Table 11. Decision rules EC-1 to EC-6 and the checks that detect breaches

Rule	Question asked	Detection check built into the process	Response if it fails
EC-1	Is this action covered by a current written authorization naming me?	Register lookup and scope-hash match at session start (AV-4, AV-6)	Stop, log, tell the Test Lead
EC-2	Is the target listed in this engagement?	Scope guard: asset ID, host name and address must all match the register entry	Stop, log; request goes to Test Lead for a scope change
EC-3	Is it inside the window and outside the blackout calendar?	Time-stamped session log compared with the window	Stop the run; resume only in window
EC-4	Am I seeing or keeping only the minimum personal data?	Evidence reviewed by a second person; masked screenshots only; planted dummy records (canary rows) in staging to show if anyone copies data out	Stop, delete local copies in front of a witness, tell the DPO
EC-5	Can this action degrade the service?	Rate limits in the tools; service-health watch by network operations	Stop, notify operations and the Test Lead
EC-6	Am I recording this honestly and at the right severity?	Second tester reviews every High or Critical rating; raw output kept next to the report	Reopen the report; refer to the Engagement Authority if altered

How the answers combine. The first six rules are evaluated in the order EC-1 to EC-6. If any answer is **no** the action is **unacceptable**: stop, log it, and tell the Engagement Authority within one hour, after which an incident review follows. If no answer is no but at least one is **unsure** the action is **borderline**: pause only that action, ask the Test Lead, and escalate to the Engagement Authority if there is no answer within 30 minutes. Work resumes only on a written reply that is logged. If every answer is **yes** the action is **acceptable** and goes ahead. The rule that fired first is recorded with the decision.

3.3 Scenario cases and how the module responds

We wrote ten cases in three groups and ran each through the decision rule above. The expected class was written down first, and the rule was then run on the answers. Table 12 shows the expected class beside the class the rule produced.

Table 12. Scenario cases run through the decision rule

Case	Action described	Expected	Rule result	Rule fired	Check
A1	Run a throttled, authenticated vulnerability scan on the LMS (SYS-03) inside the agreed window	Acceptable	Acceptable	-	Match
A2	Keep a screenshot of a vulnerable form with the personal fields masked as evidence	Acceptable	Acceptable	-	Match
A3	Stop the scan and call the Test Lead after the LMS starts responding slowly	Acceptable	Acceptable	-	Match
B1	LMS redirects to the single sign-on page (SYS-12, not listed); tester wants to see whether it is also weak	Borderline	Borderline	EC-2	Match
B2	A scan will overrun the window by about 20 minutes; tester thinks an extension is probably fine	Borderline	Borderline	EC-3	Match
B3	Tester lands on a page of real student marks and wants to scroll through it to be sure the exposure is real	Borderline	Borderline	EC-4	Match
U1	Authorization expired yesterday, tester carries on because the report is due	Unacceptable	Unacceptable	EC-1	Match
U2	Tester copies 2,000 student records to a laptop as proof of the flaw	Unacceptable	Unacceptable	EC-4	Match
U3	Tester runs a load test on the live LMS in the middle of a teaching day	Unacceptable	Unacceptable	EC-5	Match
U4	Tester lowers the severity of a finding because the system owner is a friend	Unacceptable	Unacceptable	EC-6	Match

All ten cases came out as expected, three acceptable, three borderline and four unacceptable. In the acceptable cases the tester continues. In B1 to B3 the tester pauses that one action and asks, and the answer that comes back is logged (for B1 the Engagement Authority ruled that the single sign-on directory, SYS-12, stays out of scope). In U1 to U4 the work stops and an incident review begins. Case A3 is worth noticing: stopping because a system is struggling is itself acceptable and is encouraged.

The rule separates the groups cleanly because the groups differ in a single respect. Acceptable cases have six yes answers, borderline cases have at least one unsure and no no, and unacceptable cases have at least one no. The set is small, so it shows consistency rather than full coverage; fired rules are reviewed each quarter and new cases added.

3.4 Trust, lawfulness and professionalism

Trust has two audiences. System owners need to believe testers will stay on the agreed path, and testers need to believe they will not be blamed for stopping or asking. The rules are short and public, so owners know what a tester may do, and "unsure" is a legitimate answer with a quick defined response, so testers have no reason to guess. Lawfulness is kept by tying EC-1 and EC-4 to the legal gate, and professionalism by second-checked reporting (EC-6) and a visible log. The module is reusable because the same six questions apply to any engagement, and the signed undertaking in DOC-03 binds whoever carries out the work.

Task 4 - Construct a Legal-Compliance Mapping (4 marks)

Map the engagement to the Information Technology Act, 2000 and compare it with the Computer Fraud and Abuse Act; tabulate offences, obligations and penalties; tie each to a control; decide which laws apply when personal data is touched.

This section is a design aid for the governance team. It summarises the provisions as we understand them from the statutes and from current published summaries, and it is not legal advice. The university's counsel should confirm the final wording, particularly for the penalties, which are stated as the maximum the provision allows.

4.1 The Indian and the American position side by side

Table 13. Comparison of the two statutes

Aspect	Information Technology Act, 2000 (India)	Computer Fraud and Abuse Act, 18 U.S.C. 1030 (USA)
Core wrongful act	Section 43 lists acts done without the permission of the owner or person in charge of a computer, such as accessing it, downloading data, causing damage, disrupting it, denying access, or deleting or altering information. The consequence is civil compensation.	Section 1030(a)(2) makes it an offence to intentionally access a protected computer without authorization, or exceed authorized access, and obtain information. Other subsections cover fraud, damage and extortion.
Criminal liability	Section 66 applies the same acts as an offence when done dishonestly or fraudulently: imprisonment up to three years, or fine up to five lakh rupees, or both.	Criminal on its own once access is intentional and unauthorized. A basic offence carries up to one year, aggravated forms up to five or ten years, and repeat offences are punished more heavily.
Role of permission	The wording "without permission of the owner or person in charge" makes permission the central defence.	"Without authorization" is not defined in the statute. The Supreme Court in Van Buren v. United States (2021) read "exceeds authorized access" narrowly, as a question of whether the user was entitled to access that area of the system at all.
Safe harbour for security research	None in the Act.	None in the statute. A 2022 Department of Justice charging policy says good-faith security research should not be prosecuted, but a policy is not a law and does not bind private claimants.
Data protection layer	Section 43A and the 2011 SPDI Rules apply now to sensitive personal data held by a body corporate. The Digital Personal Data Protection Act, 2023 takes over the substantive duties from 13 May 2027.	No federal general data-protection layer in the Act; state and sector laws apply.

The practical lesson from the comparison is that neither law gives a tester any protection except permission. India has no research safe harbour and the American policy is only a policy. A properly signed authorization is therefore the strongest legal control the framework can offer, which is why the authorization layer comes first in the blueprint. The comparison also shows why permission is not enough on its own: the IT Act's data-protection layer, and the DPDP Act that is replacing it, attach duties to the data itself, not just to the access.

4.2 Offences, obligations, penalties and the controls that answer them

The controls referred to below are defined in Table 15. Each legal requirement has at least one, so criterion C3 is met.

Table 14. Offences, obligations and penalties linked to framework controls

Ref	Provision	What is prohibited or required	Penalty or consequence (maximum)	Framework control
L1	IT Act s.43(a), (b)	Accessing a system, or downloading or copying its data, without the owner's permission	Compensation to the person affected	AUTH-1, LEG-1, ROE-1, DATA-3

Ref	Provision	What is prohibited or required	Penalty or consequence (maximum)	Framework control
L2	IT Act s.43(d), (e), (f), (i)	Damaging or disrupting a system, denying access to authorized users, or destroying, deleting or altering information	Compensation	ROE-2, ROE-3, ROE-4, LEG-3, LAB-1
L3	IT Act s.43A (in force until 13 May 2027)	A body corporate handling sensitive personal data must keep reasonable security practices	Compensation for wrongful loss or gain	DATA-1, DATA-2, LEG-6
L4	IT Act s.66	The s.43 acts done dishonestly or fraudulently	Up to 3 years, or fine up to Rs 5 lakh, or both	AUTH-1, EC-1
L5	IT Act s.66C and s.66D	Dishonestly using another person's password; cheating by personation, for example phishing	Up to 3 years and fine up to Rs 1 lakh each	AUTH-2, ROE-3 (test accounts only, no phishing)
L6	IT Act s.72A	A person given access to personal information under a lawful contract who discloses it without consent, causing or likely to cause wrongful loss or gain	Up to 3 years, or fine up to Rs 5 lakh, or both	LEG-4, DOC-03
L7	CERT-In Directions of 28 April 2022 (under s.70B)	Report specified cyber incidents, including unauthorized access and data breaches, within 6 hours of noticing; keep logs for 180 days	Non-compliance punishable under s.70B(7) with up to 1 year or fine up to Rs 1 lakh, or both	LEG-5, LOG-1
L8	DPDP Act 2023 s.8(2) (from 13 May 2027)	A data fiduciary may use a processor only under a valid contract	Up to Rs 50 crore under the residual entry	LEG-4, DOC-03, DOC-07 (Task 11)
L9	DPDP Act 2023 s.8(5) (from 13 May 2027)	Take reasonable security safeguards to prevent a personal data breach	Up to Rs 250 crore	DATA-1, DATA-2, DATA-3, LAB-1
L10	DPDP Act 2023 s.8(6) (from 13 May 2027)	Tell the Data Protection Board and each affected person of a personal data breach	Up to Rs 200 crore	LEG-5
L11	CFAA 1030(a)(2)	Intentional access without authorization, or exceeding authorization, to obtain information	Up to 1 year; up to 5 years if aggravated; up to 10 years for repeat	AUTH-1, LEG-2
L12	CFAA 1030(a)(5)	Knowingly transmitting damaging code, or intentionally accessing without authorization and causing damage or loss	Up to 10 years in the serious forms; civil claims also allowed	ROE-3, ROE-4, LAB-1

A few of these rows deserve comment. Row L3 will fall away on 13 May 2027, when section 44(2) of the DPDP Act omits section 43A, but until then it is the operative provision, and whether a university trust or society is a "body corporate" is arguable. We assume it is, since that is the safer reading and costs nothing in extra controls. Rows L8 to L10 are not yet enforceable at the time of writing (the substantive provisions start 18 months after the November 2025 notification), but the framework is meant to outlive that date and the penalties are large enough that building the controls now is cheaper than retrofitting them. Row L7 matters because a test can go wrong: if a tester causes or discovers an actual compromise, the six-hour reporting clock starts at that moment.

4.3 Controls introduced by the legal mapping

Table 15. Control catalogue used throughout the framework

Control	Description	Component
AUTH-1 to AUTH-3	Written authorization (DOC-02) signed by the Engagement Authority, system owner and Test Lead before any activity; roster and identity check each session (external assessors also vetted); authorization expires on its end date and can be suspended at any time.	Authorization
ROE-1 to ROE-4	Scope guard (target must match a register entry and be listed in the engagement); testing window and blackout calendar; permitted and prohibited techniques; stop-and-escalate triggers.	Scope and RoE
LEG-1 to LEG-3	Owner's permission recorded in the wording of s.43; third-party hosted systems tested only with that party's written permission or published policy, otherwise out of scope; read-only and reversible by default, nothing deleted, altered or left behind.	Legal
LEG-4 to LEG-6	Confidentiality and processor clause binding every tester (DOC-03); incident and breach reporting (CERT-In within 6 hours, DPDP intimation once in force); legal and DPO review for any T1 asset or personal data, and again for flagged findings.	Legal
DATA-1 to DATA-3	Synthetic or masked data wherever possible; evidence stored encrypted for named people and deleted 90 days after closure; personal data never copied off the system, evidence is metadata, field names or masked screenshots.	Data
EC-1 to EC-6	Code-of-conduct rules (Table 11).	Ethics
LAB-1 to LAB-4	Isolation, configuration record, reachability and egress check, snapshot and restore (Task 7).	Lab
DISC-1 to DISC-4	Report format and 24 hour notice, remediation windows, route selection, release gates (Task 6).	Disclosure
LOG-1	Append-only register and log of approvals, sessions and findings, kept at least 180 days.	Register

4.4 Which laws apply when a test touches personal data

Which laws apply. For on-premises systems without personal data the IT Act sections 43 and 66 are enough. For third-party hosted systems the provider's terms and law apply and the system stays out of scope unless permission is recorded (LEG-2). For external assessors section 75 of the IT Act reaches the act in India, and the contract binds them to Indian law (LEG-4). If a test finds or causes a real compromise, the CERT-In six-hour clock starts (LEG-5).
Decision. When a test touches a system that holds personal data, we apply the whole personal-data set and not just the access offences. That means the IT Act access provisions, section 43A and the SPDI Rules while they remain in force, the CERT-In reporting duty, and the DPDP Act duties as a design baseline from the start even though they are not enforceable before 13 May 2027. The test of "touches" is reachability: if the tester could have reached the data, the duties apply, regardless of what the tester meant to look at. We chose this because the obligations attach to the presence of the data and the university's responsibility for it, not to the tester's intentions, and because the same rule is simpler to administer than one that depends on what a tester later says they saw.

The CFAA is treated as relevant but secondary. It becomes primary only when a system is hosted or operated in the United States or the assessor is American. The email service is the likeliest case, since mail is often hosted by an overseas provider. The framework's answer is LEG-2, which keeps any such system out of scope unless the provider has given written permission or published rules that allow the planned testing. That one rule covers the CFAA risk without the university having to become expert in American law.

Task 5 - Create a Scope and Rules-of-Engagement Document (4 marks)

Design the scope and RoE document, rules for recording and verifying authorization, naming and boundaries that expose out-of-scope requests, and a pre-engagement checklist derived from the RoE.

5.1 The RoE document

The RoE is a standing template with twelve clauses. Every engagement gets its own filled copy, which is attached to the authorization form (DOC-02) and is covered by the same signatures. Table 16 lists the clauses. The example values come from the engagement used in the walkthrough in Task 9, ENG-2026-014, which assesses the LMS application and its database.

Table 16. Clauses of the rules-of-engagement document

No.	Clause	What it contains	Example for ENG-2026-014
1	Engagement identity	Engagement ID, requesting department, system owner, Engagement Authority, Test Lead, named testers, start and end dates.	ENG-2026-014; 9 to 13 November 2026; requester Computer Science; testers T-01 and T-02
2	Purpose	One or two sentences on why the test is being done and what decision it supports.	Check access controls on the LMS before the semester upgrade
3	In-scope assets	Register IDs only, each with its test mode (full or config).	SYS-03 LMS application (full); SYS-04 LMS database (config)
4	Out of scope	Everything not listed in clause 3, plus the standing exclusions in 5.2.	SYS-12 single sign-on directory, even though the LMS depends on it
5	Window and blackout	Daily window; blackout dates are taken from the university calendar and cannot be overridden by the tester.	22:00 to 05:00 IST each night; blackouts 23 Nov to 4 Dec 2026 and 4 to 15 Jan 2027
6	Permitted techniques	Taken from the profile chosen in Task 2 (TP-1 to TP-3).	TP-1 and TP-2
7	Prohibited techniques	The standing list in 5.3 plus anything the system owner adds.	As listed in 5.3
8	Data handling	Test accounts only; masked evidence; no copy off the system; evidence encrypted and deleted 90 days after closure.	DATA-1, DATA-2, DATA-3
9	Communication and escalation	Contacts and response times for each level (5.4).	See 5.4
10	Stop triggers	Events that make the tester stop at once (5.4).	See 5.4
11	Reporting and disclosure	Format (DOC-04), notice time, remediation windows and the route rules.	DISC-1 to DISC-4
12	Signatures	Engagement Authority or current deputy, system owner, Test Lead; each dated.	Three signatures required

5.2 Scope boundaries and naming

Scope disputes usually start with loose language such as "the LMS and related systems" or "the campus network". To prevent that, the RoE only accepts three kinds of identifier, and every in-scope asset must have all three recorded in the register: a **register ID** (SYS-nn), a **host name** and an **address**. Ranges, wildcards and phrases like "and related systems" are not accepted. The test for any target, which we call the scope guard (ROE-1), is: the target must match a register entry on its host name or address, and that entry must be listed in the engagement. Failing either part gives OUT-OF-SCOPE.

The standing exclusions are the same for every engagement: systems not in the register; anything hosted or operated by a third party unless that party's permission is recorded (LEG-2); personal devices of staff and students; residential and guest Wi-Fi networks that are not registered; real user accounts and credentials; physical entry; and social engineering of any kind. Social engineering is excluded because it targets people who have not agreed to take part, and because it brings in section 66D of the IT Act.

Table 17 shows the scope guard applied to six requests against engagement ENG-2026-014, which lists SYS-03 and SYS-04. The last column gives the verdict that the guard produced.

Table 17. Scope guard applied to six requests for ENG-2026-014

Requested target	What it is	Verdict	Reason given by the guard
10.20.2.10	SYS-03, the LMS application, by address	IN-SCOPE	SYS-03
lmsdb.univ.example.edu	SYS-04, the LMS database, by host name	IN-SCOPE	SYS-04
10.20.4.10	Registered (SYS-12) but not named in this engagement	OUT-OF-SCOPE	SYS-12 registered but not listed in ENG-2026-014
10.30.7.5	An address on a hostel network that is not in the register	OUT-OF-SCOPE	target not in scope register
payments.bank-partner.example	A partner bank host; not university-run	OUT-OF-SCOPE	target not in scope register
lms.univ.example.edu	SYS-03 again, by host name	IN-SCOPE	SYS-03

5.3 Permitted and prohibited techniques

Permitted by profile: TP-1 allows discovery within listed addresses, throttled scans and reading public pages and banners; TP-2 allows access-control, session and input checks using the supplied test accounts at normal request rates; TP-3 allows read-only review of configuration, patch levels, password policy and directory settings. **Prohibited** for all profiles: brute-forcing logins, exploit code against live systems, denial-of-service or stress tests, using any real person's credentials, creating, changing or deleting real records, copying personal data, persistence, backdoors, pivoting to unlisted systems, malware, phishing and wireless attacks on unregistered networks.

5.4 Escalation paths and stop triggers

Table 18. Escalation levels

Level	Who	Reached when	Response time
Level 1	Test Lead	Any doubt about scope, data or technique	15 minutes
Level 2	System owner and network operations	Service slowdown, unexpected behaviour, request to stop	30 minutes
Level 3	Engagement Authority	Out-of-scope asset reachable; borderline decision not settled at Level 1 within 30 minutes; scope change request	1 hour
Level 4	DPO, legal counsel and the Registrar's office	Personal data exposed or reachable; sign of a real intruder; legal conflict; breach reporting under LEG-5	Immediately, and within 1 hour at the latest

A tester stops at once, without waiting for permission, when any of these occurs: two health checks in a row fail on the target; the system owner or operations asks to stop; any decision rule returns "no"; traffic or evidence belonging to someone else appears; or an unlisted system becomes reachable. Restarting after a stop needs a written reply from Level 3.

5.5 Recording and verifying the written authorization

The authorization is only as good as the check made on it, so verification is written down as six rules, AV-1 to AV-6. Rules AV-1 to AV-5 are checked when the form is received. AV-6 is repeated at the start of every test session by the Test Lead and a second person.

Table 19. Authorization verification rules

Rule	Verification
AV-1	Engagement ID has the form ENG-YYYY-NNN and is unique in the register.
AV-2	All three signatures are present and dated: Engagement Authority (or deputy with a current delegation), system owner, Test Lead. No blank fields.
AV-3	Start is not after end; duration is at most 30 days; no overlap with the blackout calendar.
AV-4	Every asset ID exists in the register. The SHA-256 hash of the sorted asset list on the form equals the hash stored in the register (the scope hash).
AV-5	Testers named on the form are the people present and each has a signed DOC-03. External assessors are also on the vetted assessor roster.
AV-6	At the start of each session: status is ACTIVE, today is inside the dates, time is inside the window, and the hash is re-read from the register, not from the form. Both people initial the session line in the log.

Each engagement is recorded in the register with: engagement ID, status, requester, owner, Engagement Authority, testers, asset list and scope hash, dates, window, test profile, DPO clearance reference, and the log of approvals and sessions. The log is append-only and each entry stores the hash of the one before it, so an after-the-fact edit shows up as a broken chain.

5.6 Transformation of the RoE into a pre-engagement checklist

Reading a twelve-clause document at ten o'clock at night is how things get missed. So each clause is rewritten as a yes-or-no question with a pointer back to the clause that it came from. The Test Lead and a second person tick it together before the first session, and the completed sheet is filed in the register.

Table 20. Pre-engagement checklist derived from the RoE

No.	Check	Source	Result
1	DOC-02 is signed and dated by the Engagement Authority (or current deputy), system owner and Test Lead	Cl. 12; AV-2	Yes / No
3	Dates are within 30 days and clear of the blackout calendar	Cl. 5; AV-3	Yes / No
4	Scope hash on the form equals the hash in the register	Cl. 3; AV-4	Yes / No
5	Every asset is a register ID and none is hosted by a third party without recorded permission	Cl. 3, 4; LEG-2	Yes / No
7	Testers present match the form and each has a signed DOC-03	Cl. 1; AV-5	Yes / No
8	DPO clearance reference is recorded for any T1 asset	Cl. 8; LEG-6	Yes / No
10	Prohibited techniques have been read aloud and acknowledged	Cl. 7	Yes / No
11	Test accounts exist; no real user credentials are held by the testers	Cl. 6, 7; ROE-3	Yes / No
12	Escalation contacts verified, network operations told the window is starting, stop triggers explained	Cl. 9, 10	Yes / No
14	Encrypted evidence storage ready; deletion date written down	Cl. 8; DATA-2	Yes / No
15	Lab rehearsal record (DOC-05) completed for any intrusive technique	Cl. 6; LAB-3	Yes / No

Task 6 - Build an Authorization and Disclosure Layer (5 marks)

Create the authorization workflow, a responsible-disclosure process compared with other approaches, logging and decision operations, route-selection rules, and evidence that the layer interacts correctly with the RoE and legal components.

6.1 Authorization workflow

The workflow has seven steps. Time targets are working days and are the ones used later in the scalability evaluation. Legal and DPO review is only required when a T1 asset is involved.

Table 21. Authorization workflow (version 0.9)

Step	Name	Actor	Action	Status after	Target time	Control
S1	Request	Requesting department head	Submits DOC-01 with assets, purpose and preferred dates	SUBMITTED	Same day	AUTH-1
S2	Triage	Governance coordinator	Checks completeness; runs the scope guard on every asset; assigns tier and test profile	TRIAGED	0.5 day	ROE-1
S3	Legal and data gate	DPO	Reviews personal-data exposure; sets data handling; clears or rejects	LEGAL_REVIEW	1 day (T1 only)	LEG-6
S4	Approval	Engagement Authority or current deputy	Reads the pack and approves or rejects	APPROVED	Queue plus 1.5 h review	AUTH-1
S5	Written sign-off and recording	EA, system owner, Test Lead	Sign DOC-02; entry written to register with scope hash	SIGNED	0.5 day	AUTH-1, LOG-1
S6	Activation	Test Lead and second person	Run the pre-engagement checklist; session logged	ACTIVE	At start	AUTH-2, AV-6
S7	Closure	Test Lead	DOC-06 filed; evidence deletion date set	CLOSED or EXPIRED	Within 2 days of end	LOG-1

Every step writes a log entry. The status of an engagement can only move along the arrows in Figure 2. Skipping a step, for example going from TRIAGED straight to SIGNED, is refused.

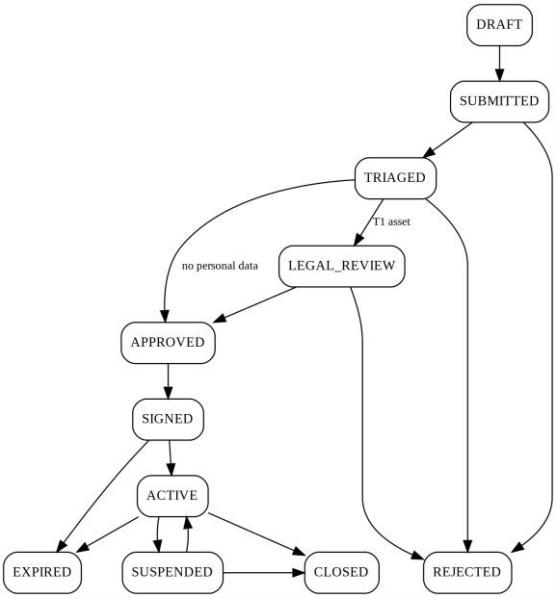


Figure 2. Status transitions allowed for an engagement

The transition rules were checked on eight moves: 5 legal moves were allowed and 3 illegal ones (for example DRAFT to ACTIVE, TRIAGED to SIGNED and CLOSED to ACTIVE) were refused.

6.2 Responsible (coordinated) disclosure process

A finding follows six stages from validation to closure. The reporting format is DOC-04 (Task 8).

Table 22. Coordinated disclosure stages and timeline

Stage	Name	What happens	Time target
D1	Validate	Test Lead confirms the finding; a second tester reviews anything rated High or Critical	Within 2 working days of detection
D2	Report	Disclosure Coordinator sends DOC-04 to the system owner's registered security contact	Within 1 working day of validation (DISC-1)
D3	Acknowledge	Owner confirms receipt and names a fixer	Within 2 working days
D4	Remediate	Owner fixes within the window for the severity: Critical 15, High 30, Medium 60, Low 90 calendar days (DISC-2). One extension of up to 50 percent is allowed with the Engagement Authority's written approval	As stated
D5	Retest	Tester checks the fix, inside an authorized window and outside blackouts	Within 5 working days of the owner saying it is fixed
D6	Close and release	Finding closed; limited internal advisory issued; quarterly summary to the Registrar; any wider release follows the route rules in 6.4 (DISC-4)	On retest pass

In this first version the remediation clock starts when the finding is validated. Task 9 shows why that was changed.

6.3 Comparison with full disclosure and bug bounties

Table 23. Comparison of disclosure approaches

Aspect	Coordinated	Full disclosure	Bug bounty
Who is told first	The system owner, privately	The public, at once	The programme operator, through a platform, from outside reporters
Time pressure	A fixed, published window	None on the owner; heavy pressure on attackers' side as well	Set by programme rules
Risk of harm before a fix exists	Low, because few people know	High, because attackers learn the flaw at the same moment as defenders	Medium; depends on how quickly reports are triaged
Control over the message	High	None	Medium
Fit for university systems	Good for all internal systems	Poor; the flaw is specific to the university and the public gains nothing	Possible later for the public website, once capacity exists

Coordinated disclosure is the default because the owners are known and reachable and the programme is young. Bug bounties need capacity to triage reports from strangers and careful legal wording, which the university lacks for now. Full disclosure is a last resort for third-party software (rule DR-4).

6.4 Rules for choosing a route

Table 24. Disclosure route rules (applied in order DR-1 to DR-4)

Rule	Condition	Route
DR-1	Evidence that the weakness is already being exploited, or that an intruder is present	Emergency notification: tell the owner and the Engagement Authority at once, contain, and start the incident clock (LEG-5). Disclosure is considered only after containment.
DR-2	Everything else (the default)	Coordinated disclosure to the owner under the remediation windows.
DR-3	Remediation window has passed without a fix or an approved extension	Coordinated and escalated: reminder at 50 percent and 80 percent of the window, escalation to the Registrar at expiry.
DR-4	All of: the flaw is in third-party software or a vendor service; the vendor is silent after two documented attempts and the window has passed; severity is High or Critical; no personal data or university-specific detail would be released; counsel and the Engagement Authority approve	Full disclosure, limited to the technical weakness in the vendor product.

Table 25. Route rules run on five example findings

Case	Finding	Route chosen	Rule
D1	High, internal LMS flaw, owner responsive, window open	COORDINATED	DR-2: default route
D2	Critical, evidence of exploitation in the wild	EMERGENCY-NOTIFY	DR-1: active exploitation, contain and notify owner and CERT-In process
D3	Medium, internal, owner missed the remediation window	COORDINATED + ESCALATED	DR-3: window missed, escalate to Registrar
D4	High flaw in vendor product, vendor silent past window, no personal data	FULL (after legal sign-off)	DR-4: vendor silent past window, no personal data, high impact
D5	High flaw in vendor product, vendor silent past window, personal data involved	COORDINATED + ESCALATED	DR-3: window missed, escalate to Registrar

D4 and D5 are the same flaw in a vendor product, and only personal data separates them: in D5 the data-protection duty outweighs the wish to push the vendor, so the route is escalated, not published. In D2 the right response to active exploitation is containment, not disclosure.

6.5 Logging and decision operations

Table 26. Operations of the authorization and disclosure layer

Operation	Checks made	Result
log_approval(eng_id, stage, actor, decision)	Actor holds the role the stage needs; the stage follows the previous one; the engagement is not closed	Appends an entry with time stamp, actor, decision and the hash of the previous entry
update_status(eng_id, new_status, actor)	The move is allowed by the transition rules; for ACTIVE the checklist reference exists	Changes status and logs it, or refuses and logs the refusal
may_disclose(eng, finding)	Engagement is ACTIVE or CLOSED; legal check passed; DPO review done where flagged; owner notified; remediation window elapsed or an exception approved	Returns allowed or blocked, with the first failing gate named
disclosure_route(finding)	Reads severity, exploitation, owner response, third-party flag, personal-data flag and overdue flag	Returns the route and the rule that decided it

Table 27. Release-gate checks run on five situations

Case	Situation	may_disclose	Reason returned
G1	ACTIVE, legal ok, DPO ok, owner notified, window elapsed	Allowed	all gates passed
G2	ACTIVE, owner notified, window still open	Blocked	remediation window still open
G3	SUSPENDED engagement	Blocked	no valid engagement
G4	DPO review pending	Blocked	DPO review pending
G5	Owner not yet notified	Blocked	owner not yet notified

6.6 Interaction with the RoE and legal components

The layer does not stand alone. Table 28 lists the places where it hands work to, or takes a constraint from, the scope and legal components. Each row refers to a test that was actually run.

Table 28. Evidence that the authorization and disclosure layer interacts with scope and legal components

Interaction	Trigger	What happened
Disclosure and scope	A finding is reported on SYS-12, which is registered but not part of ENG-2026-014	Finding report rejected: asset outside engagement scope (case F9, Table 37). The tester's observation is not exploited further; it goes to SYS-12's owner as a short "incidental observation" note through the security contact.

Interaction	Trigger	What happened
Disclosure and authorization	The engagement is suspended while a finding is waiting	Report rejected (F10) and release blocked (G3): disclosure needs an engagement that is ACTIVE or CLOSED.
Disclosure and legal	A finding is flagged as involving personal data	Release blocked until the DPO review is done (G4); a report with raw personal data attached is rejected outright (F11).
Authorization and legal	A request names a T1 asset without DPO clearance	Authorization form rejected (case I3, Table 36), so approval cannot be reached without the legal gate.
Authorization and scope	A tester starts a session outside the window or dates	The scope guard blocks the run (TC-02, TC-06; Table 39).

Task 7 - Design an Isolated Ethical-Hacking Lab (5 marks)

Design a Kali Linux and target-machine lab on a host-only network, specify components and connectivity, define verification operations, compare network options and show how the lab keeps testing authorized and contained.

7.1 Components, roles and connectivity

The lab is a single host machine running VirtualBox with three virtual machines on one host-only network, 192.168.56.0/24. Addresses are fixed by hand. The network's own DHCP server is switched off so that nothing is ever handed an address by accident. The addresses are laid out in blocks so that the role of a machine can be read from its address: .1 is the host adapter, .10 to .19 are tester machines, .20 to .29 are service targets and .30 to .39 are web targets.

Table 29. Lab components, roles and addresses

Component	Specification	Address	Role
Lab host	Laptop or workstation, 16 GB RAM, 4 or more cores, 100 GB free disk, running VirtualBox	192.168.56.1 (host-only adapter)	Runs the hypervisor and holds the baseline snapshots. Its own Wi-Fi or Ethernet is for the host only and is not shared with the guests.
Kali Linux (tester)	Current Kali Linux release; one network adapter, host-only	192.168.56.10/24, no default gateway	The authorized tester's workstation. Holds the tools.
Target A	Metasploitable 2, a deliberately vulnerable Linux image	192.168.56.20/24	Practice target for discovery, scanning and service checks. Contains no real data.
Target B	Ubuntu Server with a clone of the LMS-type web application, built from synthetic data and version-matched to production	192.168.56.30/24	Rehearsal target for the web-application checks planned for a live engagement.

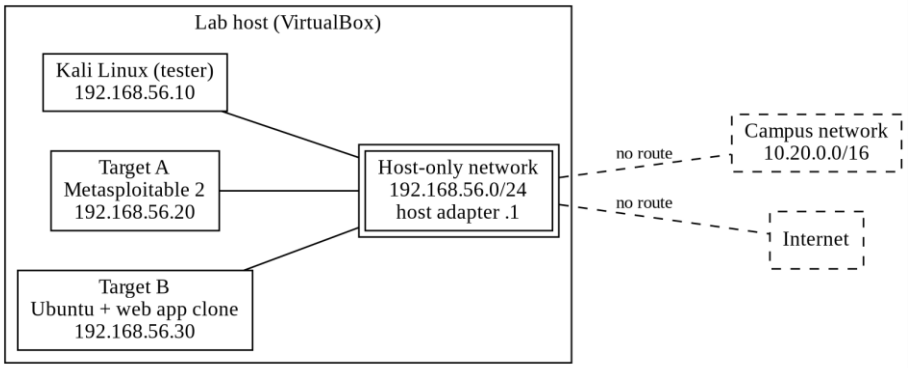


Figure 3. Isolated lab: three virtual machines on a host-only network with no path to campus or the internet

Connectivity is deliberately narrow. Kali can reach both targets and the host adapter. The targets can reach Kali and each other. Nothing in the lab has an adapter or route that leads to the campus network (10.20.0.0/16) or the internet.

7.2 Recording the lab configuration

Each build or change is written up in the lab record (DOC-05, Task 8): host operating system and VirtualBox version; each VM with adapter, network, MAC and IP address; guest operating system and, for Target B, the application version beside production (the parity check); a baseline snapshot named baseline-<date>; the SHA-256 hash of the exported configuration, stored in the register; the results of the operations in 7.3; and signatures from the Test Lead and a second person.

7.3 Operations

Four operations keep the lab honest. The commands are standard Linux and VirtualBox commands. The table gives the result we expect from a correctly built lab. When the lab is built on a real machine these are the outputs to capture as screenshots for DOC-05.

Table 30. Lab operations and expected results

Operation	Commands	Expected result	Recorded as
Op-1 record_lab_setup	On the host: VBoxManage list vms; VBoxManage showvminfo "<vm>" --machinereadable. In each guest: ip -br addr; cat /etc/os-release; uname -a	Three VMs listed; each shows a single adapter attached to the host-only network; addresses match Table 29	DOC-05 fields filled
Op-2 verify_connectivity	From Kali: ping -c 3 192.168.56.20; ping -c 3 192.168.56.30; nmap -sn 192.168.56.0/24	0 percent loss to both targets; four hosts up (host adapter, Kali, Target A, Target B)	Connectivity: pass
Op-3 verify_isolation	From Kali: ip route; ping -c 2 -W 2 1.1.1.1; ping -c 2 -W 2 10.20.2.10	Only the 192.168.56.0/24 route is listed; both pings show 100 percent loss	Isolation: pass (LAB-3)
Op-4 restore_baseline	On the host: VBoxManage snapshot "<vm>" restore "baseline-<date>"	Each VM returns to its recorded state; Op-2 and Op-3 are run again and pass	Baseline restored (LAB-4)

Op-3 is the one that matters most. Tools are never started until it has passed on the same day, and it is repeated after any change to the lab network. Updating Kali needs internet access, so updates are done in a short "build mode" with a temporary NAT adapter on Kali alone while both targets are powered off. The adapter is removed afterwards and Op-3 is run again before the lab is used.

7.4 Host-only compared with NAT

Table 31. Comparison of VirtualBox network modes for the lab

Property	Host-only	NAT	NAT network	Bridged
Guests reach the internet	No	Yes, outbound	Yes, outbound	Yes, directly
Guests can reach the campus LAN	No	Yes, through the host's connection	Yes, through the host's connection	Yes, as ordinary campus devices
Lab targets visible to others on the campus	No	No	No	Yes
Chance of stray traffic leaving the lab	Very low	High	High	Very high
Good for tool updates	No	Yes	Yes	Yes
Verdict for the attack lab	**Chosen**	Rejected for testing; used only briefly for updates	Rejected	Rejected: exposes vulnerable targets to campus

Justification. The deliberately vulnerable targets must never be reachable by anyone else, and the tester's tools must never be able to reach anything outside the list. Host-only networking gives both by construction, because there is no route out and no route in. NAT would let a mistyped address or a runaway scan leave the lab through the host, and bridged networking would put weak machines on the campus network, which is the very harm the framework is meant to prevent. The price we pay is that Kali cannot update itself while the lab is in use, and the build-mode step above handles that.

7.5 How the lab keeps testing authorized and contained

Closed address list: the only reachable addresses are 192.168.56.1, .10, .20 and .30, so a mistyped command cannot hit a real system (LAB-1). **Verified, not assumed:** Op-3 proves there is no path to campus or internet before every use (LAB-3). **Owned and synthetic:** every target is an open-source practice image or a clone built from synthetic data, so no one's permission is needed and no real data is present (DATA-1). **Recorded:** DOC-05 is signed and its configuration hash is in the register (LAB-2). **Reversible:** snapshots return the lab to a known state (LAB-4). **Linked to authorization:** rehearsal on Target B is only for techniques named in a signed engagement, and a failed readiness check blocks it (TC-13).

Task 8 - Develop a Reusable Document Library (5 marks)

Create at least four reusable engagement documents including an authorization form and a finding report, give them defaults, make one produce structured output that feeds another component, and test them with valid, boundary and invalid entries.

8.1 The library

Table 32. Reusable document library

ID	Document	Completed by	Used at	Integrates with
DOC-01	Engagement Request Form	Requesting department	Start of S1	Feeds triage and the scope guard
DOC-02	Written Authorization and Sign-off	Engagement Authority, owner, Test Lead	S5	Creates the register entry and scope hash
DOC-03	Tester Code-of-Conduct and Confidentiality Undertaking	Every tester	Before first session	Backs EC-1 to EC-6 and LEG-4

ID	Document	Completed by	Used at	Integrates with
DOC-04	Finding Report	Tester	D1 and D2	Structured output feeds disclosure, scope check and DPO gate
DOC-05	Lab Configuration Record	Test Lead	Lab build	Supports LAB-2 and the checklist
DOC-06	Closure and Disclosure Notice	Test Lead and Disclosure Coordinator	S7 and D6	Closes the register entry

8.2 DOC-02, Written Authorization and Sign-off

Table 33. DOC-02 fields and defaults

Field	Content	Default	Rule or check
engagement_id	Generated: ENG-YYYY-NNN	Next number in the register	Unique; checked by AV-1
requester, system_owner	Names and departments	None	Both required
engagement_authority	Name, or deputy with delegation end date	EA on record	Deputy needs a current delegation
test_lead, testers	Names, internal or external	None	Each tester needs a DOC-03
assets	List of register IDs	None	Every ID must be in the register
test_mode (per asset)	Full or Config	Config	T1 databases fixed at Config
start_date, end_date	Dates	End = start + 14 days	End not before start; at most 30 days; clear of blackouts
window	Daily test hours, IST	22:00 to 05:00	May be overnight
test_profile	TP-1 to TP-4	TP-1	TP-4 is design review only
dpo_clearance	Reference number	Required if any T1 asset	Blocks signing if missing
data_handling	Text from DATA-1 to DATA-3	Synthetic or masked data only	Fixed wording
scope_hash	SHA-256 of the sorted asset list	Generated	Compared with register by AV-4
signatures (three)	EA, owner, Test Lead, each dated	None	All three needed
status	Workflow status	DRAFT	Moves only along allowed transitions
evidence_retention_days	Number	90	Fixed by DATA-2

8.3 DOC-04, Finding Report

Table 34. DOC-04 fields and defaults

Field	Content and rule	Default
finding_id	FND-YYYY-NNN-SSS (engagement number plus sequence)	Generated
engagement_id, asset_id	Must refer to a registered asset listed in that engagement	None
title, summary	Short plain-language description. No raw data and no exploit code	Summary required
cvss_score	Number from 0.0 to 10.0, with the vector string	None
severity	Derived from the score: 0.0 Info, 0.1 to 3.9 Low, 4.0 to 6.9 Medium, 7.0 to 8.9 High, 9.0 to 10.0 Critical	Derived
personal_data_flag	Yes if the weakness can expose personal data	No; Yes sends it to the DPO
exploited_in_wild, third_party_component	Yes or No	No, No
evidence_refs	Identifiers of masked evidence items	None
validated_by	Second tester for High and Critical	Test Lead
notify_by	Validation time plus 1 working day	Generated
remediate_by	Acknowledgement plus window for the severity	Generated
disclosure_route	Result of rules DR-1 to DR-4	COORDINATED
status	OPEN, ACKNOWLEDGED, FIXED, RETESTED, CLOSED	OPEN

Other documents. DOC-01 carries request_id, requester, owner, assets requested, objective, preferred dates, whether personal data is expected (default: unknown, treated as yes), and the profile wanted. DOC-03 carries the tester's name, organization, identity number, engagements covered, a declaration that EC-1 to EC-6 have been read, confidentiality and processor clauses, a statement accepting Indian law and jurisdiction, signature and date; confidentiality lasts two years after the engagement by default. DOC-05 carries the lab fields in 7.2. DOC-06 carries the engagement ID, counts of findings by severity, each finding's status, outstanding items, the route used, lessons learned, and the date the evidence was deleted (default: closure plus 90 days).

8.4 Structured output of the finding report

A validated DOC-04 does not just sit in a folder. It produces a small structured record that the rest of the framework reads. Table 35 is the record produced for the first test finding, FND-2026-014-001, a missing object-level authorization check on a course-file download endpoint of the LMS, scored 7.5.

Table 35. Structured record produced by DOC-04 (output of the validator)

Field	Value produced	Consumed by
finding_id	FND-2026-014-001	Key in the register
engagement_id	ENG-2026-014	Authorization layer checks status ACTIVE or CLOSED
asset_id	SYS-03	Scope guard confirms the asset is listed in the engagement
severity	High	Selects the remediation window (DISC-2)
notify_by_hours	24	Starts the notification clock (DISC-1)
remediate_days	30	Sets the owner's deadline
dpo_review	YES	Sends the finding to the DPO gate (LEG-6) before release

8.5 Test entries

Both key documents were tested with valid, boundary and invalid entries (12 entries each, 24 in all). The expected result was written first, then the validators were run. The tables show the most informative entries, including every boundary that matters.

Table 36. Test entries for DOC-02 (V valid, B boundary, I invalid)

Case	Entry	Expected	Result	Reason returned
V1	Valid, T1 assets, DPO cleared, 5 days	ACCEPT	ACCEPT	-
V2	Valid, T3 assets only (SYS-14, SYS-18), no DPO needed	ACCEPT	ACCEPT	-
B1	Boundary: duration exactly 30 days	ACCEPT	ACCEPT	-
B2	Boundary: duration 31 days	REJECT	REJECT	duration over 30 days
B4	Boundary: ends 22 Nov, day before the examination blackout	ACCEPT	ACCEPT	-
B5	Boundary: ends 23 Nov, first day of the blackout	REJECT	REJECT	overlaps blackout period
I1	Invalid: system owner signature missing	REJECT	REJECT	missing so_sign
I3	Invalid: T1 asset without DPO clearance	REJECT	REJECT	SYS-03 is T1, DPO clearance missing

Table 37. Test entries for DOC-04 (engagement ACTIVE unless stated)

Case	Entry	Expected	Result	Reason returned
F1	Valid: CVSS 7.5, personal-data flag set	ACCEPT	ACCEPT	-
F3	Boundary: CVSS 0.0 (informational)	ACCEPT	ACCEPT	-
F4	Boundary: CVSS 3.9	ACCEPT	ACCEPT	-
F5	Boundary: CVSS 4.0	ACCEPT	ACCEPT	-
F7	Boundary: CVSS 9.0	ACCEPT	ACCEPT	-
F8	Invalid: CVSS 10.1	REJECT	REJECT	cvss out of range
F9	Invalid: asset SYS-12 not in this engagement	REJECT	REJECT	asset outside engagement scope
F10	Invalid: engagement is SUSPENDED	REJECT	REJECT	engagement status SUSPENDED
F11	Invalid: raw personal data attached	REJECT	REJECT	raw personal data attached

All 24 entries behaved as expected. The boundary cases do the most work: 30 and 31 days, a single-day engagement, an end date on either side of the blackout, and scores of 3.9, 4.0, 8.9 and 9.0 on either side of a severity band. These are the places where mistakes in a form usually hide.

Integration. The authorization form creates the register entry and scope hash that the scope guard and AV-4 read. The finding report reads the engagement status, the scope register and the severity table, and writes the record that the disclosure layer and the DPO gate act on. A change to the register therefore changes the behaviour of both documents without anyone editing the forms.

Task 9 - Integrate, Test and Refine the Framework (5 marks)

Integrate Tasks 2 to 8 into one framework, walk an authorized assessment from request to disclosure, run systematic test cases, and record the problems found and the refinements made.

9.1 The integrated framework

The parts built in Tasks 2 to 8 join into a nine-stage lifecycle (Figure 4). Each stage uses at least one control defined earlier, and each hands a named record to the next (the authorization layer passes the engagement ID and scope hash, the scope component passes verdicts, the legal gate passes clearance, and DOC-04 passes the structured record to disclosure). The register and log sit under all of it.

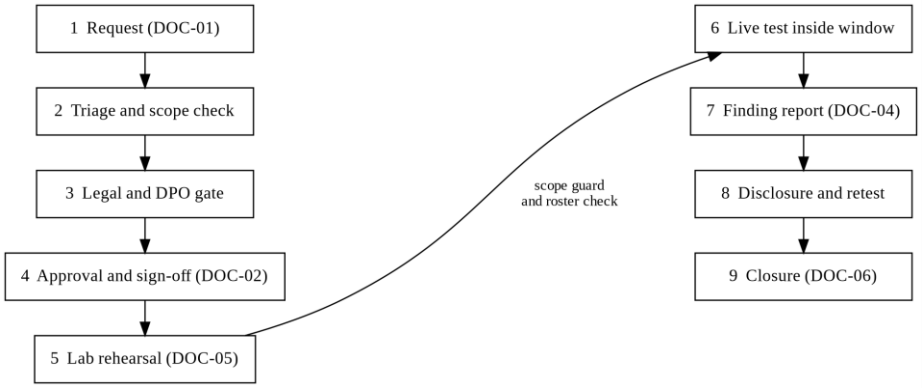


Figure 4. Lifecycle of an engagement from request to closure

9.2 Walkthrough of an authorized assessment

The walkthrough follows engagement ENG-2026-014, an assessment of the LMS application (SYS-03) and its database (SYS-04) before the semester upgrade. It is a constructed walkthrough on paper, with D0 taken to be Monday 2 November 2026, and the dates are illustrative. The test results quoted come from the validator runs in Task 8 and the checks in 9.3. The finding is described only at the level of its category, and no technique details are given.

Table 38. Walkthrough of ENG-2026-014

Day	What happens	Component	Control or note
D0	Computer Science submits DOC-01 for SYS-03 and SYS-04 (SUBMITTED). Triage: the scope guard finds both assets in the register, both T1; profiles TP-1 and TP-2 chosen (TRIAGED).	Authorization, scope	AUTH-1; ROE-1
D1	DPO review: personal data (names, marks) sits behind the LMS, so the database is config-only, application tests use two test accounts and no data leaves the system (LEGAL_REVIEW).	Legal	LEG-6; DATA-1 to DATA-3
D2 to D3	The Engagement Authority is travelling, so the deputy approves under a delegation ending 6 November (P5). DOC-02 is signed by deputy, owner and Test Lead; two testers sign DOC-03; register entry and scope hash written (SIGNED).	Authorization, ethics	AV-1 to AV-5; P5
D4 to D6	Lab: Target B built as an LMS clone with synthetic data. Op-1 to Op-3 pass, but the parity check shows the clone is one minor version behind production, so rehearsal is blocked until it is updated (P6). Baseline snapshot taken; access-control checks rehearsed.	Lab	LAB-1 to LAB-4; TC-13
D7	First session, 22:00 on 9 November. Checklist done, AV-6 passes (ACTIVE). The draft dates had run into the examination period; the blackout check caught this and they were moved (P1).	Authorization, scope	ROE-2; P1
D7	The LMS login redirects to the single sign-on directory (SYS-12). EC-2 answers "unsure": the tester stops, the Engagement Authority rules SYS-12 out of scope, and the reply is logged (P2).	Ethics, scope	Case B1; TC-04
D7 to D11	Nightly sessions inside the window on SYS-03 with test accounts; SYS-04 reviewed read-only. On D8 a weakness is confirmed: a course-file download endpoint does not check who may see the file. Tested only between two test accounts; the tester stops.	Scope, ethics	ROE-2 to ROE-4
D9	DOC-04 completed: CVSS 7.5 (High), personal-data flag set. The second tester confirms and the validator accepts it (F1): High, 24 h notice, 30 days, DPO review YES. Report goes to the owner within 24 hours (P3).	Disclosure, legal	DISC-1; LEG-6
D10	Owner acknowledges; remediation due 12 December, the clock starting at acknowledgement (P4). The owner reports a fix on 20 November.	Disclosure	DISC-2
D11	Testing ends (CLOSED). The DPO confirms only test-account data was reached, so there is no breach and no CERT-In report.	Authorization, legal	LEG-5 not triggered
D35 to D36	Retest on 7 December, after the blackout ends on 4 December, under a short addendum; it passes. Finding closed, limited internal advisory issued, DOC-06 filed, evidence deletion date set 90 days ahead.	Disclosure, register	DISC-4; DATA-2; LOG-1

The route for this finding is coordinated disclosure to the owner (rule DR-2). It is internal, there is no sign of exploitation, and a public release would only help someone who wishes the university harm.

9.3 Systematic test cases

Thirteen cases cover the four situations the assignment names: missing authorization, out-of-scope requests, legal conflicts and delayed disclosure. Each case was run through the checks, and each result below is the one the checks returned.

Table 39. Systematic test cases and results

Case	Category	Situation	Expected	Result	Reason returned
TC-01	Missing authorization	Missing authorization (status DRAFT)	BLOCK	BLOCK	AUTH: engagement DRAFT
TC-02	Missing authorization	Expired authorization (14 Nov, one day after end)	BLOCK	BLOCK	AUTH-1: outside authorized dates
TC-03	Missing authorization	Tester not on authorized roster	BLOCK	BLOCK	AUTH-2: tester not on roster
TC-04	Out of scope	Out-of-scope request: SSO directory SYS-12	BLOCK	BLOCK	ROE-1: SYS-12 registered but not listed in ENG-2026-014
TC-05	Out of scope	Out-of-scope request: partner payment host	BLOCK	BLOCK	ROE-1: target not in scope register
TC-06	Out of scope (time)	In-scope asset, daytime (14:00)	BLOCK	BLOCK	ROE-2: outside testing window
TC-07	Control: should pass	In-scope asset inside window (23:00)	ALLOW	ALLOW	all gates passed
TC-08	Legal conflict	Legal conflict: test would copy personal data off-system	BLOCK	BLOCK	LEGAL: conflict flagged
TC-09	Out of scope (time)	Blackout day (24 Nov) reached despite approved dates	BLOCK	BLOCK	ROE-2: blackout calendar
TC-10	Delayed disclosure	Owner missed the 60 day window on a Medium finding (day 61)	COORDINATED + ESCALATED	COORDINATED + ESCALATED	DR-3: window missed, escalate to Registrar
TC-11	Delayed disclosure	Finding validated 26 hours ago, owner still not notified	ALERT	ALERT	DISC-1 breached, escalate to Engagement Authority and log
TC-12	Missing authorization	Approval signed by deputy whose delegation ended 1 Nov (approval on 3 Nov)	BLOCK	BLOCK	delegation expired
TC-13	Lab readiness	Lab target is older than the production LMS version (parity fails)	BLOCK	BLOCK	lab target version differs from production (parity)

All thirteen results matched. TC-07 is the control case. It shows that the checks do not simply refuse everything, and that a correct request passes all gates at once.

9.4 Problems found and refinements made

The walkthrough was useful mostly because it went wrong in six places. Table 40 records what went wrong, why, how the framework was changed, and which test now guards against the problem. The corrected framework is version 1.0.

Table 40. Problems met in the walkthrough and the refinements made

No.	Problem	Cause	Refinement	Guarded by test
P1	Proposed dates overlapped the examination period; nothing in the form caught it	RoE had a window but no calendar	Blackout calendar added to RoE clause 5 and to AV-3; checked automatically	B4, B5, TC-09
P2	The tester reached the single sign-on directory through the LMS login; scope was unclear	Forms listed assets but not their dependencies	"Dependent assets" field added to DOC-02; default rule: dependents are out of scope unless listed	TC-04, case B1
P3	No one was named to review a finding that might expose personal data	Legal gate existed only before approval	Personal-data flag added to DOC-04; release blocked until DPO review (gate added to may_disclose)	F1, F11, G4
P4	Unclear when the remediation clock starts; 30 days from validation penalized the owner for the reporting delay	Clock defined on validation (version 0.9)	Clock now starts at the owner's acknowledgement; reporting itself has its own 24 hour target	TC-10, TC-11
P5	Approval stalled because the Engagement Authority was away	Single approver, no delegation rule	Deputy role with written delegation and end date added; delegation expiry checked	TC-12
P6	The lab clone ran an older LMS version than production, so the rehearsal would not have been representative	DOC-05 had no parity field	Parity check added to DOC-05 and to the pre-engagement checklist; rehearsal blocked if it fails	TC-13

After these six changes the whole set of test cases in Tasks 3, 5, 6, 8 and 9 was run again and gave the same results as before, so none of the fixes broke earlier behaviour. The corrected framework, version 1.0, is the one carried into the scalability evaluation.

Task 10 - Create a Scalability and Governance Evaluation (5 marks)

Compare a small and a large programme, measure at least three processes, tabulate and chart the results, and use the evidence to refine the governance.

10.1 Scenarios and evaluation setup

We could not run a real programme at university scale, so the evaluation is a queueing simulation of the process steps with stated assumptions. The numbers show how the design behaves as load grows. They are not measured values from a real university, and they should be recalibrated with actual timings once the programme has run for a quarter.

The **small programme** is one department with 6 systems, 2 internal testers, one Engagement Authority, 4 engagements and about 24 findings a month, and one disclosure coordinator. The **large programme** is 12 departments and 200 systems with 25 testers (15 internal, 10 external from four firms), an Engagement Authority and deputy (plus 12 departmental security officers in version 1.1), 30 engagements and about 180 findings a month (6 per engagement), and two coordinators.

Table 41. Evaluation setup and assumptions

Item	Setting
Time and arrivals	21 working days per month; 252 working days simulated per run; Poisson arrivals; first-come first-served queues
Service times	Uniform, 40 percent either side of the mean given below; random seeds fixed (42, 7, 11, 13) so the runs repeat exactly
Approval, version 1.0	Every request goes to the Engagement Authority; 1.5 hours of review per request; 2.5 hours a day available for approvals. Triage 0.5 day and sign-off 0.5 day; legal review (1 day) for the 40 percent of requests that involve a T1 asset, done one step after another
Approval, version 1.1	60 percent of requests (low risk) go to departmental security officers (1.0 hour, 2 hours a day each); 40 percent (T1) go to the Engagement Authority and deputy (1.0 hour on a standard pack). Legal review runs in parallel
Disclosure, version 1.0	One report per finding, 0.75 hour each, coordinator has 5 hours a day
Disclosure, version 1.1	One digest per engagement, 1.0 hour each, same coordinator hours
Scope verification (not simulated)	Counted by steps. Minutes per engagement are an assumption: 22 minutes with manual register checks, 3 minutes with the register-based scope guard

10.2 Results for three processes

Table 42. Comparison of version 1.0 and version 1.1 at small and large scale

Measure	Small, v1.0	Small, v1.1	Large, v1.0	Large, v1.1
Approval turnaround				
Mean (working days)	2.1	1.5	4.5	1.5
95th percentile (working days)	2.7	2.0	8.7	1.7
Approved within 5 working days (%)	100	100	66	100
Steps (T1 path)	8	8	8	8
Steps (low-risk path)	8	6	8	6
Load on approver (% of available hours)	11	3 (EA), 6 (DSO)	86	11 (EA), 4 (DSO)
Scope verification				
Steps per engagement	6	3	6	3
Minutes per engagement (assumed)	22	3	22	3
Disclosure notification				
Mean wait before owner is told (office hours)	2.3	1.7	4.3	2.0
Owner told within 1 working day (%)	98	100	86	99
Steps	6	5	6	5
Load on coordinators (%)	17	4	64	14

Load figures are simple arithmetic from the setup (requests times review time, divided by hours available), and the other figures come from the simulation. Disclosure counts are the numbers of reports handled in the 252-day run, 286 findings small and 2,117 findings large for version 1.0, against 47 and 339 digests for version 1.1.

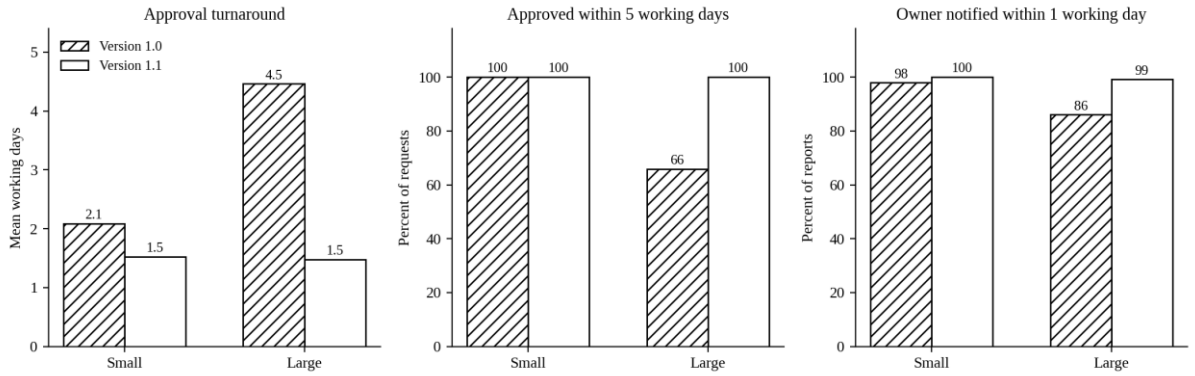


Figure 5. Approval turnaround, on-time approval and on-time owner notification at small and large scale

10.3 Interpretation

At small scale version 1.0 works well. Turnaround is about two days and every approval lands inside the five-day target. At large scale the picture changes. The Engagement Authority has to review every request, and at thirty engagements a month this uses about 86 percent of the hours available for approvals. A queue forms. Mean turnaround more than doubles to 4.5 days, the slowest 5 percent wait nearly nine days, and only two thirds of requests are approved inside five days. The design fails criteria C5 and C6 as soon as it grows. The ratio of large to small turnaround is 2.1, against a limit of 1.5.

Disclosure follows the same pattern, more gently. Writing one report for every finding is fine for 24 findings a month, but at 180 findings a month the coordinators fall behind and only 86 percent of owners are told within a working day, below the 95 percent target.

10.4 Governance refinements made because of the results

Table 43. Governance refinements introduced in version 1.1

No.	Refinement	Evidence from the evaluation
R-1	Tiered approval: low-risk engagements (no T1 asset, config-only or TP-1) go to the departmental security officer; T1 engagements stay with the Engagement Authority or deputy, who samples 10 percent of delegated approvals each quarter. A one-page standard approval pack cuts review to 1.0 hour, and legal review runs in parallel with approval	Large-scale mean turnaround falls from 4.5 to 1.5 days and on-time approval rises from 66 to 100 percent; the Engagement Authority's load falls from about 86 to about 11 percent
R-2	Digest reporting: one DOC-04 digest per engagement for non-critical findings; Critical findings are still sent singly	Large-scale owner notification within one day rises from 86 to 99 percent; coordinator load falls from 64 to 14 percent
R-3	Machine-readable scope register and a scope-guard script run by the tester and the second person	Steps fall from 6 to 3 and time from about 22 to 3 minutes per engagement
R-4	Pre-vetted roster of external assessors, vetted once and not per engagement	Needed to keep the approver load low when the 10 external testers join; checked in Task 11

The cost of R-1 is that some approvals are no longer made by the most senior person; the sampling and the register log are the checks against that. After the refinement, the large programme meets C5 (100 percent approved within five days, 99 percent notified within a day) and C6 (a large-to-small turnaround ratio of 0.97).

Task 11 - Defend the Framework Under a Changed Requirement (5 marks)

The university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline. Revise the framework, add or modify components, defend the result with evidence, and state remaining trade-offs.

11.1 What the changed requirement does to the design

Four things change at once. Testing is continuous, so a signature per test no longer fits. Outside firms carry out part of it, so the university's duties pass through contracts. Data-protection rules are stricter, so assessors should see less real data than before. And disclosure is faster, so the clock in the existing process is too slow. Version 1.1 was built for one-off engagements, so the pressure falls on authorization, the RoE and disclosure.

11.2 Retain, modify, replace or redesign

Table 44. Decisions for each component in version 2.0

Component	Decision	What changes	Evidence it rests on
Register and log, lab, code of conduct	Retain, extend	Register gets a machine-readable interface for scheduled runs; the lab gets an ephemeral rebuild; EC-1 to EC-6 apply unchanged to outside firms, with processor undertakings added to DOC-03	Walkthrough; TC-13; all ten cases in Table 12

Component	Decision	What changes	Evidence it rests on
Scope guard (ROE-1)	Retain, extend	Run automatically before every scheduled run, not only at session start	TC-04 and TC-05
Threat model	Modify	Add the third-party assessor as an insider-type risk (misuse of access or data); keep TP-1 to TP-4	Table 7
Legal mapping	Modify	DPDP Act duties become the binding baseline; processor contract and breach intimation made explicit	Rows L8 to L10 of Table 14
Document library	Modify, add	DOC-02 gains assessor organisation and dependent assets; new DOC-07 and DOC-08 (below)	Table 36 and Table 37
Disclosure layer	Modify	Shorter windows; critical lane with immediate notice	11.4
Authorization layer	Replace the single-test form for routine work	Standing authorization for profiles of non-intrusive tests, renewed every 90 days; one-off authorization remains for intrusive tests	Walkthrough P2, P5; Task 10 load
Rules of engagement	Redesign	From one document per engagement to a standing RoE plus a short addendum for each profile or test	Task 10: approvals were the bottleneck

11.3 New and modified components

Assessor Gate (new). Before any outside tester can be named on a form, the firm and each individual pass a gate. The firm signs a processor contract that carries the clauses in DPDP Act section 8(2), the confidentiality clause that engages section 72A of the IT Act, Indian law and jurisdiction, and a promise that data stays on university systems. Each individual signs DOC-03, is identity-checked, and is added to the assessor roster, and access is only through a university jump host with multi-factor sign-in and recorded sessions. The checklist for this is a new document, DOC-07. Authorization rule AV-5 now checks the roster, so an unvetted assessor cannot appear on a valid form.

Continuous Assessment Profile, CAP (new, with DOC-08). A CAP describes a recurring test: the asset IDs, the technique list (non-intrusive only: scheduled authenticated scans, configuration and dependency checks), the schedule, rate limits, who is told, and an expiry of 90 days. A CAP is approved once and renewed, instead of being re-signed at every run. Before each run, the scheduler re-reads the register and compares the scope hash on the CAP with the register (rule AV-4 applied automatically). A mismatch, an expired CAP or a failed health check cancels the run and raises an alert, and the system owner and Engagement Authority each have a kill switch.

Data access levels (modified legal gate, new control DATA-4). Level 0 is synthetic data only and is the default for all assessors. Level 1 is masked data. Level 2 is real data in the smallest amount needed, only with the DPO's written sign-off for that run, viewed through the jump host with no download. Evidence retention falls from 90 to 30 days; log retention stays at 180 days to match the CERT-In directions.

Faster disclosure (modified, DISC-2 and new DISC-5). Remediation windows are shortened to Critical 7, High 15, Medium 30 and Low 60 days, running from the owner's acknowledgement. Critical findings go down a separate lane with two on-call responders and a four-hour notice target. Other findings continue to use the digest with a one-working-day target.

How the new parts connect to the old. The Assessor Gate feeds the authorization layer through the roster that AV-5 reads. The CAP reads the same register and scope guard as before, and its findings use the same DOC-04, validator and route rules, with the shorter windows read from the same severity table. Nothing from the original design had to be thrown away, which is the test of whether the framework is easy to extend. Figure 1's structure still holds; only the authorization, RoE and disclosure boxes change, and the Assessor Gate, CAP and critical lane are added.

11.4 Defence using the evidence

Table 45. Evidence for the version 2.0 design

Requirement	Measure	Result	Source
Continuous testing is easy to govern	Approvals needed per quarter, large programme	90 in version 1.1; about 50 in version 2.0 (standing authorization renewals plus new requests), 44 percent fewer	Task 10 setup
Approvals stay quick	Large-programme mean turnaround and on-time rate, version 2.0	1.5 working days; 100 percent within 3 working days	Simulation, same method as Task 10
Shorter disclosure is achievable	Critical findings told within 4 office hours	Version 1.1 digest queue: 92 percent. Version 2.0 with one responder: 87 percent. Two responders: 99 percent (mean 0.8 hours)	Simulation of 18 critical findings a month
Non-critical disclosure keeps up	Owners told within 1 working day, large programme	99 percent (version 1.1 figure retained)	Task 10
Data protection is stricter	Legal rows with a control; assessor data level	All 12 rows of Table 14 have controls; default access Level 0; evidence kept 30 days	Task 4
Authorization still reliable	Missing, expired and out-of-scope cases	TC-01 to TC-06, TC-09, TC-12 all blocked; unchanged under the new rules because AV-4 and AV-6 are reused	Task 9

Requirement	Measure	Result	Source
Walkthrough lessons carried over	Problems P2 and P4	P2 became explicit dependent assets in each CAP; P4's clock rule was kept for the shorter windows	Task 9

The first attempt at the critical lane used a single responder and reached the four-hour target only 87 percent of the time, which is worse than the existing digest queue's 92 percent. We put the evidence ahead of the idea and added a second on-call responder, which brought it to 99 percent.

11.5 Final check against the design criteria

Checked against the seven criteria of Task 1, version 2.0 meets all of them: **C1** standing authorizations still carry a register entry, scope hash and per-run log; **C2** the scope guard runs before every scheduled run (TC-04, TC-05 blocked); **C3** all 12 legal rows have controls and the DPDP duties are the baseline; **C4** CAPs use non-intrusive techniques only, with blackout calendar and kill switch; **C5** in the large programme 100 percent of approvals fall inside 5 days and 99 percent of owners are told inside a day; **C6** the large-to-small turnaround ratio is 0.97 against a limit of 1.5; **C7** all 24 document test entries behaved as expected and the two new documents follow the same pattern.

11.6 Trade-offs, limitations and future improvements

- **Standing authorization widens the blast radius.** One mistake in a CAP now repeats on every run. The limits are non-intrusive techniques only, the automatic scope check, the kill switch and a 90-day expiry. They reduce the risk but do not remove it, since a compromised scheduler account could still run authorized profiles at the wrong time.
- **Shorter windows push owners hard.** Seven days for a Critical fix may force quick, shallow patches or exceed what a department can do. The single permitted extension with written approval is the safety valve, but owner capacity is not modelled anywhere in this evaluation.
- **Less real data means less realistic tests.** Synthetic data cannot reproduce every flaw that depends on real content, so some weaknesses will be missed. Level 2 access per run reduces this at the price of DPO time and more risk.
- **The numbers are simulated.** The service times are assumptions. If real reviews take twice as long, the conclusions about the tiered lane need to be checked again.
- **Everything depends on the register.** If the register is wrong, the scope guard cheerfully enforces the wrong scope. Ownership of the register and quarterly reconciliation against real asset lists are required.

Future improvements. Use digital signatures on DOC-02 and DOC-07 in place of scanned ones. Connect the register to the ticketing system so that findings, fixes and retests are tracked automatically. Recalibrate the simulation with real timings after one quarter. Commission an external audit of the framework once a year. Consider a small bug-bounty pilot for the public website (SYS-18) when two quarters of stable operation show that report triage is manageable. Add a tabletop exercise for state-level actors (TP-4) to the yearly calendar.